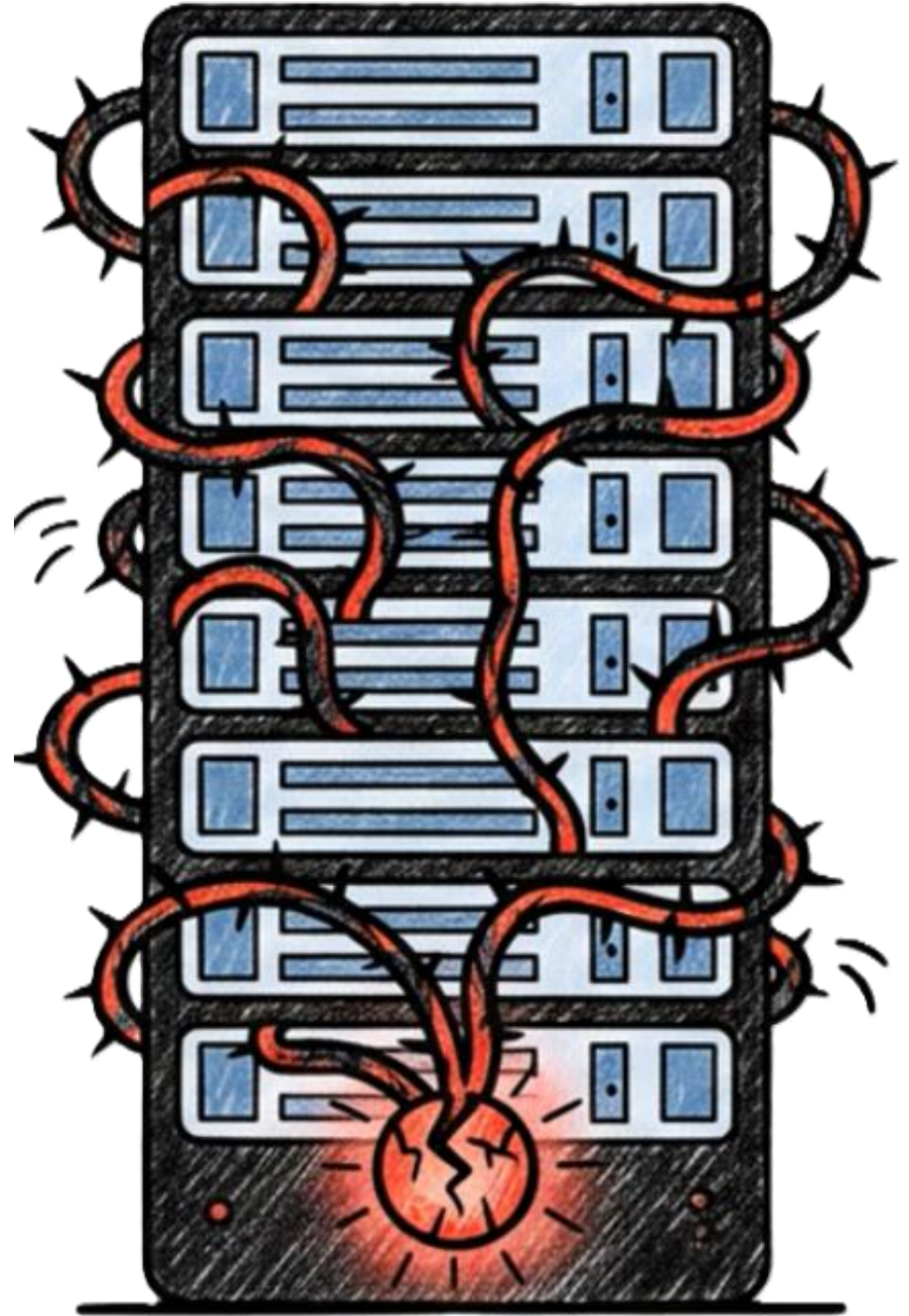


cPanel Zero-Day Exploit



Chaos





چطور میره داخل ولی بررسی
نمیشه ؟؟؟!!!

The Chaos



این آسیب پذیری به
مهاجمان از راه دور
غیرمجاز اجازه می دهد تا
به سطح root دسترسی
پیدا کنند.



The Chaos



بازه زمانی قابلیت بهره برداری



زنجیره بهره‌برداری — CVE-2026-41940

چهار درخواست HTTP، بدون اعتبارنامه، دسترسی کامل ریشه.

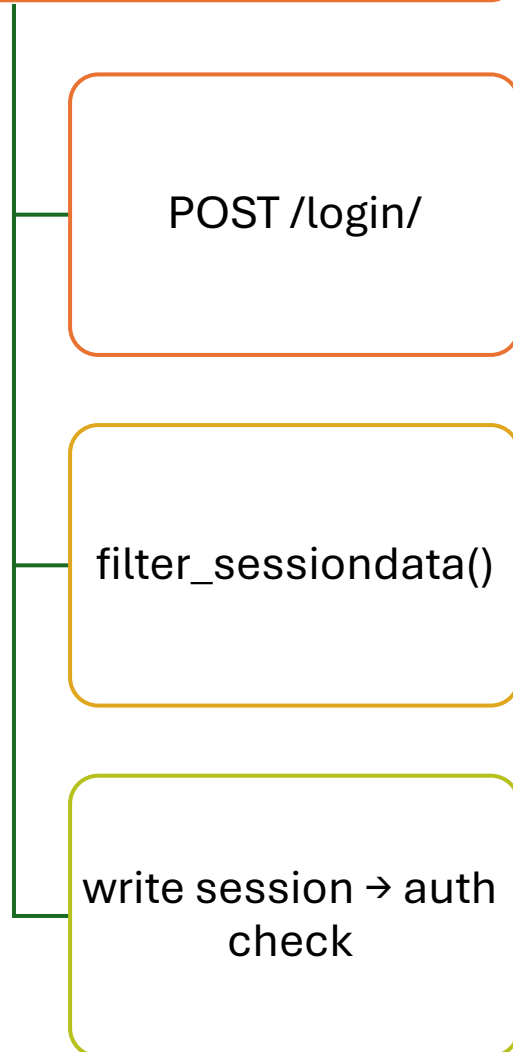


The Chaos



بررسی جریان ها

Normal flow



Vulnerable flow



مرحله	کاری که مهاجم می‌کند	پاسخ اشتباهی که سرور درست می‌کند
۱	ورود عمداً ناموفق را ثبت می‌کند	به هر حال یک فایل <code>preauth</code> <code>session</code> روی دیسک ایجاد می‌کند
۲	یک درخواست احراز هویت پایه با اعتبارنامه‌های دارای خط جدید، با استفاده از کوکی‌ای که بخش کلید رمزگذاری را حذف می‌کند، ارسال می‌کند.	اعتبارنامه‌ها را بدون رمزگذاری و پاکسازی روی دیسک می‌نویسد
۳	درخواستی ارسال می‌کند که کنترل‌کننده‌ی <code>token denied</code> را فعال می‌کند.	فایل خام آلوده را دوباره تجزیه می‌کند و حافظه پنهان <code>JSON</code> را بازنویسی می‌کند و خطوط تزریق شده را به فیلدهای سطح بالا منتقل می‌کند.
۴	هر درخواست احراز هویت شده معمولی را انجام می‌دهد	نشست را به عنوان کاربر ریشه در نظر می‌گیرد و به دلیل علامت «قبلاً احراز هویت شده» از بررسی رمز عبور صرف نظر می‌کند.



چطور بهره برداری کنیم؟ (اخلاقی)

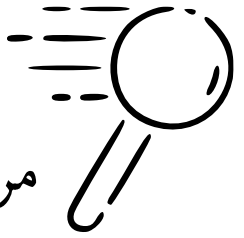


The Chaos





مرور سریع CRLF



یک مثال payload خوب

```
root:x
successful_internal_auth_with_timestamp=9999999999
user=root
tfa_verified=1
hasroot=1
```

از ماشین‌های تحریر قدیمی سرچشمه می‌گیرد:
ابتدای خط و `\n` آن را به یک خط پایین‌تر می‌برد.

در HTTP و بسیاری از پروتکل‌های مبتنی بر متن، `\r\n` در کنار هم به معنای "پایان این خط. شروع یک خط جدید" هستند.

چرا خطرناک است: اگر یک برنامه ورودی کاربر را دریافت کند و آن را بدون پاکسازی در یک فایل یا جریان پروتکل باشد، مهاجم می‌تواند خطوط `\r\n` بنویسد، و آن ورودی شامل جدیدی تزریق کند - و عملاً ساختار داده‌ها را بدزدد.

The Chaos



استفاده از dork های shodan

http.title:"cPanel" port: 2082, 2083, 2086, 2087

product:"cPanel" port:2087

ssl.cert.subject.cn:"cPanel" port:2087



سیس exploit با ابزار cPanel Sniper

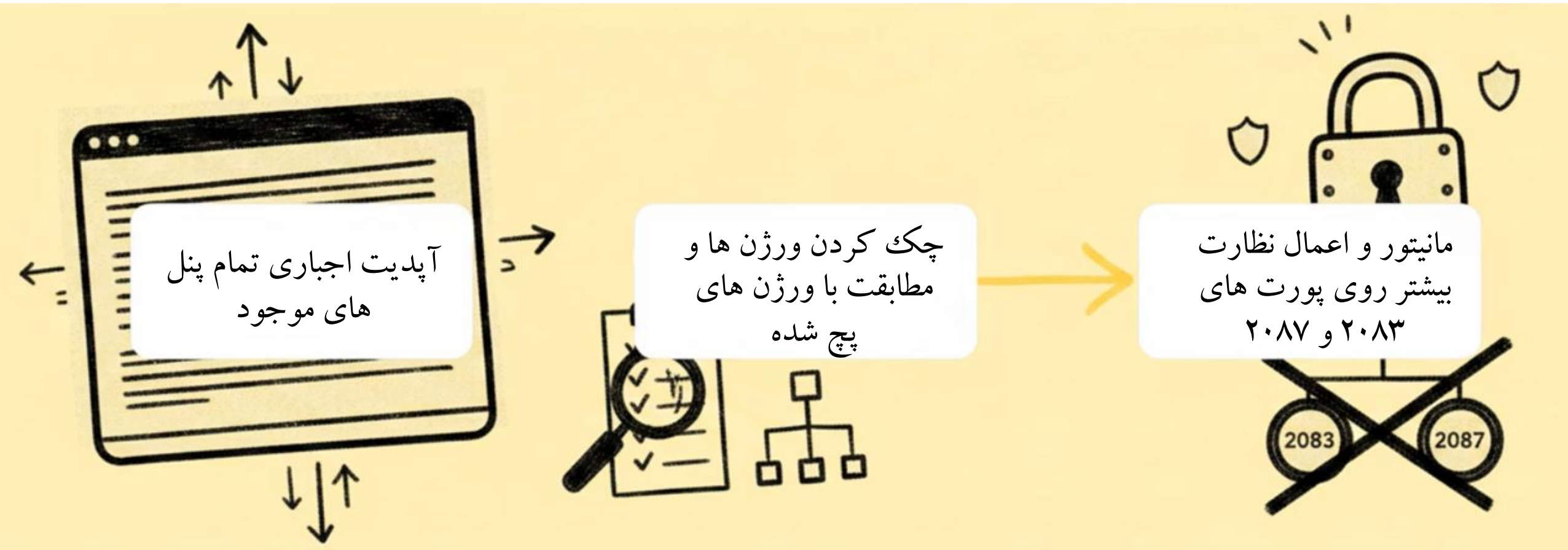
<https://github.com/ynsmroztas/cPanelSniper>



The Chaos



توصیه های پیشگیری و جلوگیری



The Chaos

